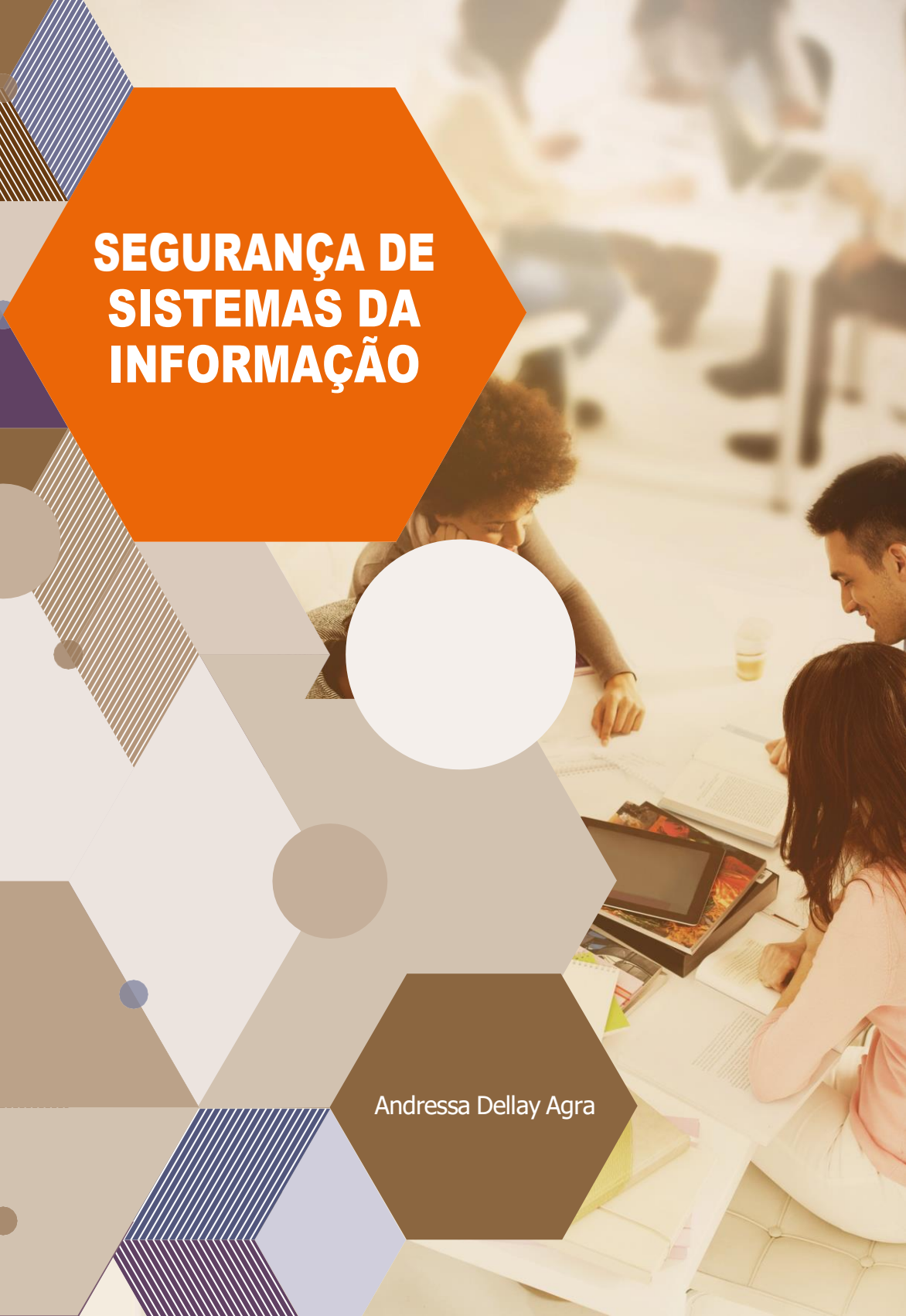


The background of the cover is a photograph of three people (two men and one woman) sitting around a table, looking at papers and a tablet. The image is overlaid with various geometric shapes: a large orange hexagon in the top left, a white circle in the center, and several grey and blue hexagons and circles of different sizes. Some of these shapes have diagonal line patterns.

SEGURANÇA DE SISTEMAS DA INFORMAÇÃO

Andressa Dellay Agra

Tipos comuns de invasão

Objetivos de aprendizagem

Ao final deste texto, você deve apresentar os seguintes aprendizados:

- Descrever os tipos comuns de invasão e as principais técnicas usadas.
- Reconhecer os tipos de ataques de negação de serviço.
- Identificar os ataques na *web* (clientes e servidores).

Introdução

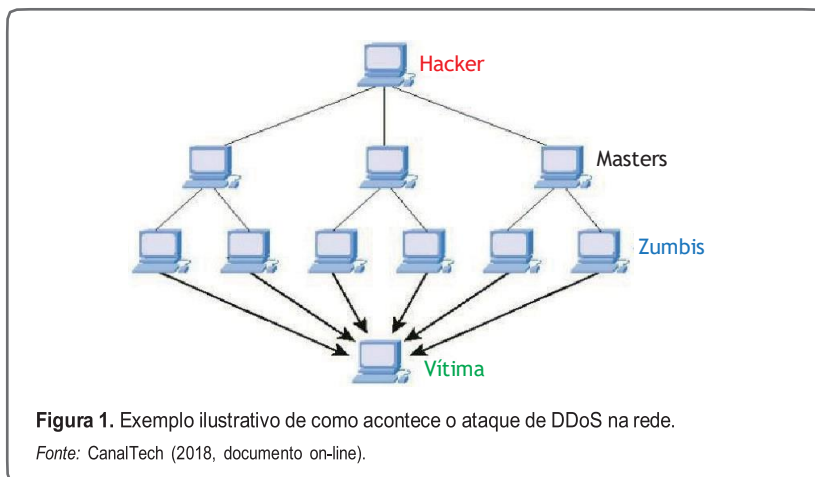
O uso de serviços na *web* vem crescendo de maneira abrangente, com ataques surgindo, por consequência, a todo momento. Com frequência, são observadas falhas nas aplicações *web*, como a vulnerabilidade das páginas, servidores e transição de dados a bancos de dados. Por isso, tornam-se necessários profissionais que conheçam o que está acontecendo no mundo cibernético.

Neste capítulo, você conhecerá sobre os tipos comuns de invasão, como as invasões *web* de clientes e servidores, as negações de serviços e as principais técnicas utilizadas por invasores.

Invasões comuns e principais técnicas

Os tipos de ataques mais comuns utilizados por invasores são citados a seguir. **DDoS Attack**, sigla de **Distributed Denial-of-Service**, é conhecido como “ataque de navegação de serviço” (Figura 1), uma maneira relativamente simples de derrubar um serviço. Seu objetivo consiste em tornar uma página ou um processo indisponível para o usuário final. Para realizar esse ataque, o invasor precisa criar uma rede zumbi (BotNet), que inclui uma infinidade de computadores infectados de maneira que um *host* “mestre” possa controlar. No momento em que o *cracker* escolhe seu alvo, ele envia o IP para o computador “mestre”, que se encarrega de distribuí-lo para a rede de computadores “zumbis”. Essa rede será responsável por sobrecarregar o alvo (p. ex., um servidor) até que se torne indisponível.

Em geral, os invasores empregam a obstrução da mídia de comunicação entre os utilizadores e o sistema de modo a não se comunicarem corretamente. Outra maneira de realizar o ataque consiste em forçar a vítima a reinicializar ou consumir todos os recursos de memória, processamento ou de outro *hardware* a fim de deixá-lo impossibilitado de fornecer o serviço. Por ter múltiplas fontes, o rastreamento e o bloqueio desse tipo de ataque são mais complicados.



Audiodescrição

A imagem mostra um diagrama em formato de árvore. No topo, há um computador com a palavra **Hacker** em vermelho. Abaixo dele, ligado por uma linha vertical, aparecem três computadores, um no centro, um à esquerda e outro à direita. O computador à direita tem o texto **Masters** em preto.

Na linha seguinte, há seis computadores distribuídos horizontalmente. À direita, há a palavra **Zumbis** em azul. Setas pretas partem desses computadores inferiores em direção a um computador posicionado na parte inferior do diagrama. Esse computador inferior está marcado com a palavra **Vítima** em verde.

Figura 1. Título: Exemplo ilustrativo de como acontece o ataque de DDoS na rede.

Fonte: CanalTech (2018).

Fim da audiodescrição

Port Scanning Attack compreende uma técnica muito empregada pelos responsáveis pela segurança da informação, com a finalidade de encontrar fraquezas em um servidor ou vulnerabilidades no sistema. Normalmente, está relacionado ao uso de *softwares* maliciosos para que explore as brechas

dos sistemas.

Esse ataque consiste em enviar mensagens para uma porta e esperar por uma resposta. O dado ou informação recebidos indicam ao *hacker* se aquela porta está disponível ou não, o que o ajudará a encontrar a melhor maneira de invadir o servidor.

Cavalos de Troia, vírus e *malwares* são programas maliciosos desenvolvidos por invasores com o objetivo de destruir o alvo. Os vírus e *worms* (programa autorreplicante que pode ser projetado para realizar ações maliciosas após infestar um sistema e, inclusive, deletar arquivos) normalmente se aderem a um sistema de modo a inviabilizar o uso de uma máquina ou de uma rede como um todo. Normalmente, esse ataque se inicia por e-mail ou os programas ficam escondidos dentro de aplicações de interesse do usuário.

Os cavalos de Troia são parecidos — infectam o computador da mesma maneira, mas normalmente oferecem ao *hacker* acesso ao computador vitimado, passando diversos tipos de informações.

Algumas ações mais comuns do cavalo de Troia:

- criar portas dos fundos — normalmente alteram o sistema de segurança de modo que outros *malwares*, ou *crackers*, consigam invadir;
- espionar — alguns cavalos de Troia são *spyware* (programa automático de computador que recolhe informações sobre o usuário), projetados para aguardar até que o usuário acesse contas on-line ou insira dados de cartão de crédito. Depois, enviam suas senhas e dados pessoais de volta ao computador “mestre” (de onde veio o ataque);
- transformar computadores em zumbis — nesse caso, o interesse do invasor consiste em fazer o seu computador virar um escravo em uma rede sob seu controle.

Ataques de força bruta tentam adivinhar usuários e senhas por meio de tentativa e erro. Se o invasor souber o nome do usuário, apenas precisará descobrir a senha deste. Na internet, existe até mesmo um dicionário de senhas mais comuns entre os usuários.

Eavesdropping é um ataque que se baseia na violação da confidencialidade de informações e dados: o invasor, por meio de recursos tecnológicos, aproveita a vulnerabilidade nas comunicações de possíveis vítimas fazendo um monitoramento sem autorização durante essa comunicação, podendo roubar dados e informações a ser usadas posteriormente.

Esse tipo de ataque se aproveita de conexões não encriptadas, ou encriptadas, usando algoritmos fracos. Redes locais, baseadas em *hubs* ou redes *wireless*, sem segurança, são alvos fáceis, bastando plugar o *notebook* no *hub* ou colocá-lo dentro da área de alcance do ponto de acesso para capturar

as transmissões.

O **spoofing** é um ataque no qual o invasor se passa por outro aparelho ou usuário de uma rede. Tem os objetivos de roubar dados, disseminar *malwares* ou contornar controles de acesso. Suas formas mais comuns são o *spoofing* de IP, e-mail e DNS. O *spoofing* tenta enganar uma rede ou uma pessoa fazendo-a acreditar que a fonte de uma informação é confiável.



Exemplo

Um invasor pode realizar o *spoofing* de e-mail enviando a você — usuário — uma mensagem que pareça se originar de alguém ou empresa em quem ou em que confia: isso fará com que informe dados sigilosos.

Nesse caso, temos a técnica de *phishing*, na qual os dados são pescados por um relapso do usuário.

O **bluejacking** envia imagens, mensagens de texto e sons aos dispositivos próximos via Bluetooth. Além de invadir a privacidade de quem utiliza os aparelhos, o programa encaminha *spam*.

O **adware** é um modelo de *software* de invasão de privacidade, que exhibe anúncios na tela de um usuário sem o seu consentimento. Em geral, é instalado no computador de um usuário porque ele visitou uma página infectada, abriu um anexo de e-mail infectado, instalou um programa que tinha *adware* embutido em um cavalo de Troia ou surge como resultado de um vírus ou um verme de computador. Quando estiver instalado e executando em segundo plano, um programa *adware* periodicamente exibirá um anúncio na tela do usuário. O **spyware** é um *software* de invasão de privacidade instalado em um computador de usuário sem sua autorização, coletando informações sobre ele. Normalmente, a infecção do *spyware* envolverá outros programas, que sempre estarão em execução em segundo plano, consumindo a memória e o processamento do seu computador. Muitas vezes, uma infecção com esse tipo de *software* pode modificar o sistema operacional de modo que o *spyware* seja sempre executado como parte da sequência de inicialização do sistema. O computador infectado normalmente trabalha em modo de lentidão.

Vejamos algumas das diferentes ações executadas por um *spyware*.

- Captura de teclas: também conhecida como *keylogging*, refere-se ao monitoramento das ações de uma tecla de computador registrando cada tecla pressionada. Normalmente, tem a intenção de resgatar senhas,

informações de *login* e outras informações confidenciais, como o número de cartão de crédito. Esse tipo de interceptação pode funcionar capturando cada tecla pressionada, retornada pelo *hardware* e gravando-a em um local oculto, antes de passar as informações obtidas para o sistema operacional.

- **Captura de tela:** capturar uma tela de usuário pode revelar uma grande quantidade de informações. Uma infecção de *spyware*, que usa capturas periódicas de telas, pode comprometer a privacidade do usuário. Um *spyware*, que se mantém anônimo no sistema operacional, deve fazer capturas de tela a uma taxa relativamente baixa do uso da memória.
- **Rastreamento de *cookies*:** *cookies* são arquivos de internet que armazenam temporariamente aquilo que o internauta está visitando na rede. Eles fornecem uma maneira de *sites* manterem o estrado entre várias visitas do mesmo usuário, como um modelo de lembrete, e proporcionam uma experiência de navegação personalizada. Quando o internauta visita um *site* pela primeira vez, este pode solicitar um arquivo, denominado *cookie*, para que seja colocado em seu computador a fim de armazenar as informações úteis sobre as páginas acessadas. Infelizmente, um grupo de *sites* pode agir de maneira maliciosa e solicitar que *cookies* de determinada nomenclatura e tipo sejam instalados, de modo a poder a fazer um rastreamento coletivo quando um usuário visitar qualquer um de seus *sites*. *Cookies* utilizados como no exemplo são visualizados como um tipo de *spyware*, mesmo que não exista um *software* instalado no computador do usuário.



Exemplo

Um exemplo de utilização de *cookies* rastreadores são as empresas de publicidade. Aquelas com anúncios em diversas páginas da *web* empregam esse sistema para identificar quais de seus *sites* clientes foram visitados por um usuário em particular.

- **Coleta de dados:** esse tipo de *spyware* evita problemas e riscos associados ao monitoramento de ações do usuário. Sua intenção é procurar dados pessoais ou proprietários nos arquivos de computadores infectados.



Exemplo

Dois exemplos que se pode citar para a coleta de dados são:

- inclusão de programas que procuram uma lista de contatos do usuário para coletar endereços de *e-mails* que possam ser utilizados para *spams*;
- programas que procuram documentos, planilhas e apresentações de slides capazes de conter dados de interesse do desenvolvedor do *spyware*.



Fique atento

Você já ouviu falar nas **zonas cinzas**? Zonas cinzas envolvem a instalação de *spywares* bem-intencionados, pois estão em uma zona ética, usados de forma consciente — ou seja, eles têm a intenção de monitorar o que está sendo acessado nos computadores, como o caso de pais que monitoram o uso de computadores de seus filhos. Trata-se de um tipo de sistema voltado a manter segurança em relação aos acessos de uma máquina.

Ataques de negação de serviços

Identificados como *Denial-of-Service Attack* (DoS), esses ataques fazem com que recursos sejam explorados de modo que usuários legítimos fiquem impossibilitados de utilizá-los. Em outras palavras, qualquer ataque planejado para fazer uma máquina ou um *software* ficar indisponível e incapaz de executar sua funcionalidade básica é conhecido como ataque de negação de serviço.

Nesse tipo, a falsificação do endereço IP de origem é comumente usada para obscurecer a identidade do atacante. O uso de falsificação de IP dificulta a identificação da fonte de um ataque DoS.

Ataque ICMP (*Internet Control Message Protocol*)

Existem dois ataques de negação de serviço que exploram ICMP:

- **ataque de inundação por *ping*** — o utilitário *ping* envia uma requisição de *echo* ICMP para um *host*, que, por sua vez, responde com um *echo* ICMP. Para considerar esse ataque, uma máquina, considerada potente, envia uma quantidade grande de requisição de *echo* para um único servidor vítima. Se o atacante conseguir criar mais requisições *ping* do que a vítima pode processar, então o servidor atacado ficará sobrecarregado pelo tráfego e começará a descartar conexões legítimas;
- ***smurf*** — trata-se de um ataque no nível de rede no qual um grande tráfego de pacotes é enviado para o endereço IP (*Internet Protocol*) de *broadcast* (método de transferência de mensagem para todos os receptores simultaneamente) da rede, tendo como origem o endereço de origem da vítima. Caso o número de máquinas na rede que recebem e respondem aos pacotes enviados seja extenso, o computador da vítima será infestado com o tráfego. Isso pode atrapalhar o computador da vítima, impossibilitando trabalhar nele.

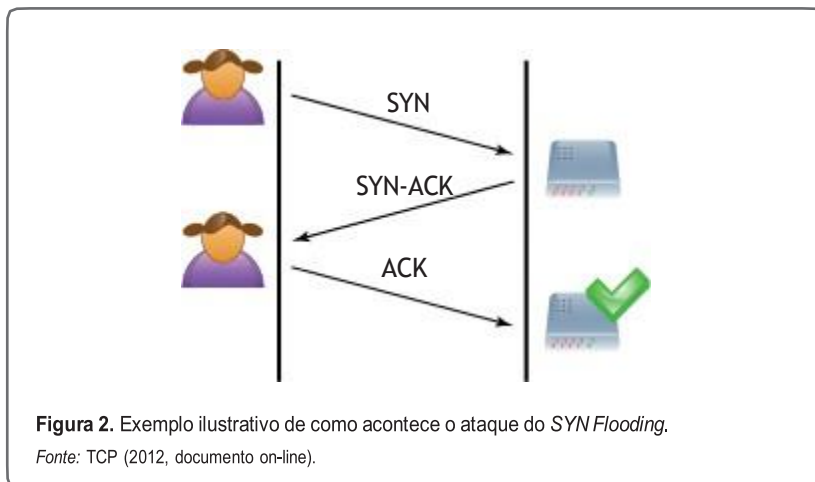
Outros ataques de negação de serviço

O *Fraggle* utiliza pacotes UDP *echo* (*User Datagram Protocol*) em vez de ICMP *echo* (*Internet Control Message Protocol*). As máquinas na rede, ao receberem o pacote UDP, respondem à vítima, que, por sua vez, envia mais uma resposta, gerando uma grande quantidade de tráfego na rede.

Já o ***SYN Flooding*** corresponde a um ataque que explora o mecanismo de estabelecimento de conexões TCP (*Transmission Control Protocol*, ou Protocolo de Controle de Transmissão). Os ataques relacionados ao *SYN flooding* (Figura 2) se caracterizam pelo envio de um grande número de requisições de conexão, fazendo com que o servidor não consiga responder a todas elas. Nesse caso, a pilha de memória sofre uma sobrecarga e as requisições de conexões de usuários são desprezadas.

O ataque se dá quando o cliente tenta começar uma conexão TCP com um servidor, que passam a trocar uma série de mensagens entre si normalmente assim:

- o cliente requisita uma conexão enviando um SYN (*synchronize*) ao servidor;
- o servidor confirma essa requisição mandando um SYN-ACK (reconhecimento de sincronização) de volta ao cliente.
- o cliente, por sua vez, responde com um reconhecimento, e a conexão está estabelecida.



Audiodescrição

A imagem apresenta dois personagens estilizados posicionados à esquerda. Cada personagem tem rosto circular em tom alaranjado e cabelo em tom marrom.

Ao centro da imagem, há uma linha vertical preta separando os personagens dos dispositivos à direita. À direita dessa linha, aparecem dois equipamentos de rede representados como caixas retangulares em cinza, com pequenas luzes coloridas na parte frontal. O equipamento inferior tem sobre ele um ícone de marca de verificação verde.

Três setas diagonais pretas ligam os personagens aos equipamentos. A seta superior parte do personagem superior em direção ao equipamento superior e contém o texto **SYN**. A seta central parte do equipamento superior em direção ao personagem superior e contém o texto **SYN-ACK**. A seta inferior parte do personagem inferior em direção ao equipamento inferior e contém o texto **ACK**.

Figura 2. Exemplo ilustrativo de como acontece o ataque do *SYN Flooding*.

Fonte: TCP (2012).

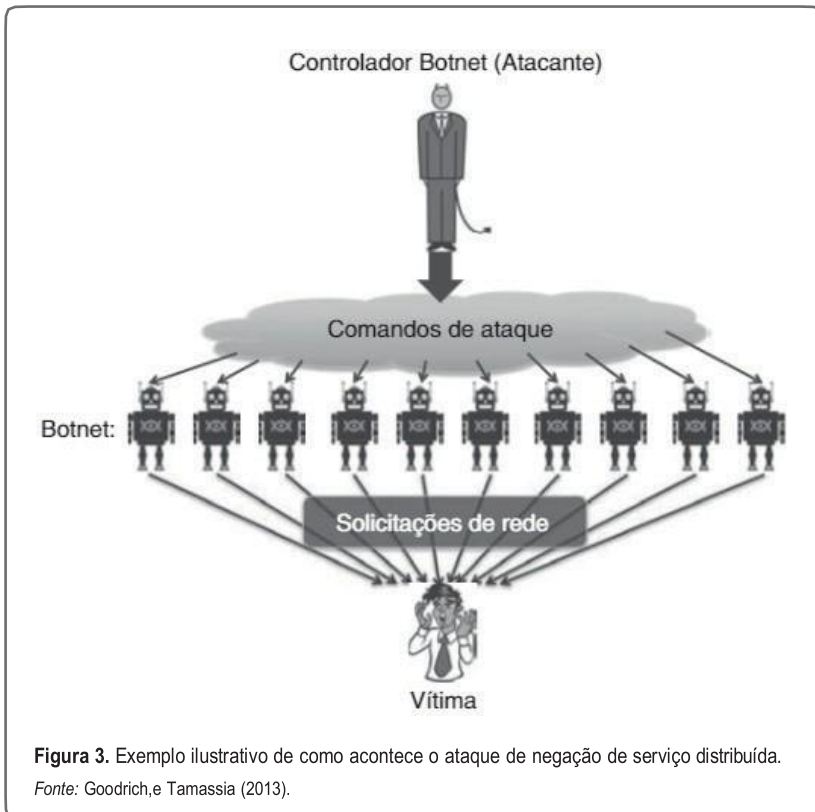
Fim da audiodescrição

No **ataque otimista ACK TCP**, o número de pacotes TCP como pendentes, durante uma sessão de comunicação TCP, antes de requisitar um ACK, é conhecido como janela de congestionamento. À medida que um servidor recebe ACK de um cliente, ele ajusta dinamicamente o tamanho da janela de congestionamento para refletir a estimativa de largura de banda disponível. Nesse ataque, o mecanismo de congestionamento de TCP funciona contra ele mesmo. Um pretenso cliente tenta fazer um servidor aumentar a sua taxa

de envio até que esgote a sua largura de banda e não consiga atender mais ninguém com eficiência. Caso seja realizado simultaneamente contra vários servidores, esse ataque pode também criar um congestionamento na internet entre as vítimas e o atacante. Ele é feito pelo cliente que envia ACK para pacotes ainda não recebidos para fazer o servidor aumentar sua velocidade de transmissão. A intenção do cliente consiste em fazer o reconhecimento de pacotes que tenham sido enviados pelo servidor, mas ainda não recebidos pelo cliente.

Negação de serviço distribuída

A maioria dos ataques de negação de serviço é impraticável a partir de uma única máquina. As condições de negação de serviço ainda podem ser criadas usando mais de uma máquina atacante, a que se dá o nome de ataque de negação de serviço distribuída (Figura 3). Nesse tipo de ataque, invasores combinam a potência de muitas máquinas para direcionar o tráfego contra um único *site*, em uma tentativa de criar condições de negação de serviço.



A imagem mostra, na parte superior, um homem de terno identificado pelo texto Controlador Botnet (Atacante). Abaixo dele, há uma seta grossa preta apontando para baixo. A seta direciona para uma área sombreada em cinza, onde está o texto Comandos de ataque.

Logo abaixo da área sombreada, há uma fileira horizontal composta por dez robôs. Cada robô tem corpo retangular, braços e pernas mecânicos e uma tela no centro do corpo. À esquerda da fileira, aparece o texto Botnet.

De cada robô, partem setas pretas diagonais voltadas para a parte inferior da figura.

As setas convergem para um retângulo cinza com o texto Solicitações de rede.

Abaixo desse retângulo, há uma personagem humana segurando um dispositivo.

Embaixo dessa personagem, aparece o texto Vítima.

Figura 3. Título: Exemplo ilustrativo de como acontece o ataque de negação de serviço distribuída.

Fonte: Goodrich e Tamassia (2013).

Fim da audiodescrição



Saiba mais

Sites como Yahoo!, Amazon e Google têm sido alvos de repetidos ataques DDOS. Com frequência, os atacantes conduzem ataques de negação de serviço usando *botnets* — grandes redes de máquinas comprometidas e que são controláveis remotamente.

Bugs em serviços e sistemas operacionais

Infelizmente, alguns dos maiores responsáveis por ataques de negação de serviços são os desenvolvedores de sistemas. Falhas na implementação e na concepção de serviços, aplicativos, protocolos e sistemas operacionais viabilizam sua exploração em ataques contra a organização.

Vejamos alguns *bugs* e condições de *softwares* que têm como resultado a negação de serviço:

- **buffer overflow** — condições de *buffer* podem ser usadas para executar códigos arbitrários nos sistemas, considerados de alto risco. É preciso saber que grande parte das vulnerabilidades encontradas nos sistemas refere-se a um *buffer overflow*. Nesse tipo de ataque, o invasor explora

bugs de implementação nos quais o controle da memória temporária para armazenamento dos dados não tenha sido feito adequadamente;



Saiba mais

O site de leilões online eBay foi invadido em março de 1999 pela exploração de uma condição de *buffer overflow*, em um programa com *SUID root*. O *hacker* instalou um *backdoor* que interceptava a digitação do administrador, possibilitando que nomes de acesso e senhas fossem facilmente capturados. Com um acesso de superusuário, o invasor pôde realizar várias operações no site, como modificar preços dos produtos em leilão, manipular ofertas, etc.

- condições inesperadas — manipulação errada e incompleta de entradas por meio de diferentes camadas de códigos Perl script, que recebem parâmetros pela *web* e, se forem explorados, podem fazer com que o sistema operacional execute comandos específicos;
- entradas não manipuladas — código que não define o que fazer com entradas inválidas e estranhas;
- *format string attack* — ataque a uma aplicação, em que se explora a semântica dos dados, fazendo com que sequências de caracteres nos dados fornecidos sejam processadas de modo a realizar ações não previstas ou permitidas, no âmbito do processo do servidor;
- *race conditions* — quando mais de um processo tenta acessar os mesmos dados ao mesmo tempo, podendo causar confusões e inconsistências das informações.

Fragmentação de pacotes de IP

A fragmentação de pacotes está relacionada à Maximum Transfer Unit (MTU), que especifica a quantidade máxima de dados que podem passar em um pacote por meio físico da rede.

A possibilidade de invasões por meio de fragmentação de pacotes de IP resulta do modo como a fragmentação e o reagrupamento são implementados: os sistemas não tentam processar o pacote até que os fragmentos, em totalidade, sejam recebidos e reagrupados. Isso possibilita a ocorrência de *overflow* na pilha TCP, quando há o reagrupamento de pacotes maiores que o permitido.

Ataques na web (clientes e servidores)

A internet é utilizada para inúmeras atividades, como serviços bancários, compras, educação, comunicação, notícias, entretenimento, redes sociais, etc. Pelo fato de ter grande acesso e estar em constante ascensão, há uma preocupação com a segurança das informações e a privacidade na *web*.

As páginas *web* utilizam o *Hypertext Markup Language* (HTML), ou seja, são escritas (desenvolvidas) pela “Linguagem de Marcação de Hipertexto”. Para acessarmos um *site*, utilizamos um navegador, como Mozilla Firefox, Google Chrome, Opera, entre outros, que são interpretadores, isto é, identificam um *site* com um *uniform resource locator* (URL).



Exemplo

URL corresponde aos endereços que utilizamos para acessar determinado site. Por exemplo,

`http://www.exemplo.com/paginas/arquivo.html`

Desmembrando o endereço, temos:

- **http** — protocolo de acesso a uma página (existem outros, como https e ftp);
- **www.exemplo.com** — domínio do servidor web, que contém o site de interesse;
- **página** — nome da pasta que está armazenando o site de interesse;
- **arquivo.html** — arquivo que descreve os textos e as imagens para uma página no site desejado.

A URL, conhecida amigavelmente por um conjunto de palavras pelos usuários da internet, transforma-se em um DNS, ou seja, o endereço que escrevemos na barra de endereços de um navegador é traduzido para um número que o identifica, com a finalidade de que a requisição aconteça de forma rápida ao servidor. Para termos um bom entendimento sobre DNS, a base será o número 128.34.66.120, o qual será requisitado ao servidor para que uma página retorne visualmente ao usuário.

Após estabelecer uma conexão TCP (Protocolo de Controle de Transmissão) com o servidor, o navegador envia requisições, conhecidas como requisição HTTP (Protocolo de Transferência de Hipertexto), para o servidor (Figura 4). Uma requisição HTTP especifica o arquivo que o navegador quer receber do servidor. As requisições ao servidor consistem em um comando GET ou POST.



Audiodescrição

A imagem apresenta, à esquerda, um computador de mesa composto por uma torre em preto e um monitor com tela em tom azul. Abaixo do conjunto, aparece o texto **Cliente**.

À direita, há um servidor representado como um gabinete grande em tom escuro, com várias baias visíveis na parte frontal. Abaixo do servidor, está o texto **Servidor**. Entre computador e servidor, há uma seta horizontal vermelha apontando da esquerda para a direita. Sobre essa seta, está o texto **HTTP**.

Figura 4. Título: Requisição entre cliente e servidor.

Fonte: Padilha, (2015, documento *on-line*).

Fim da audiodescrição

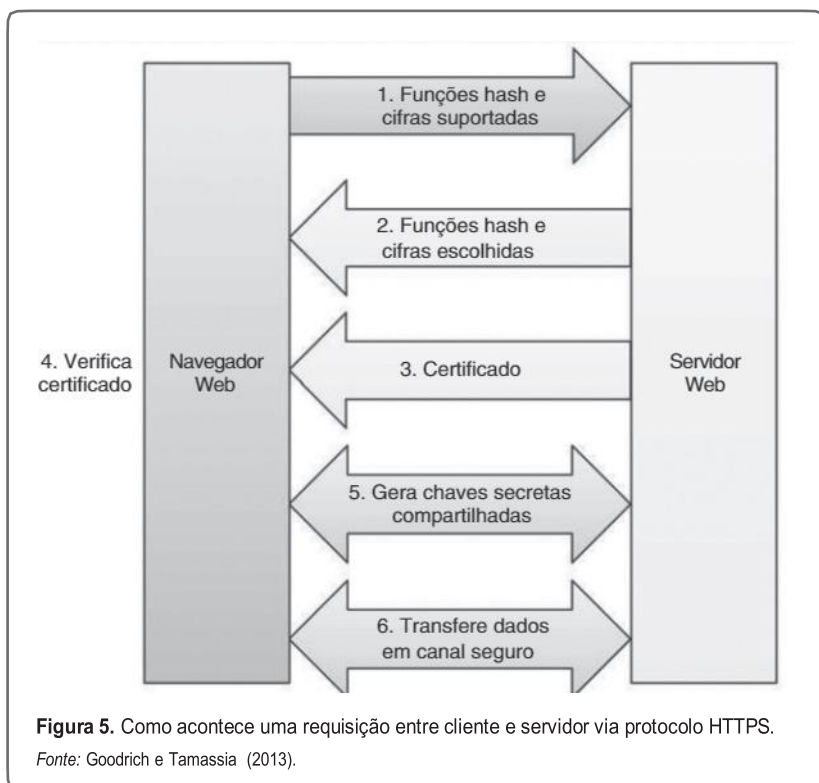
Formulários HTML — existem para que um usuário consiga entrar em contato com determinada empresa pela internet, podendo usar dois métodos para submeter dados: GET e POST.

Quando usuários enviam os campos do formulário preenchidos e o código utilizado internamente na página HTML é o GET, os dados informados são codificados diretamente para URL, separados por “&”, como em `http://www.exemplo.com/form.php?nome=Teste&sobrenome=Teste de TI`, no qual nome e sobrenome compreendem os campos preenchidos com as variáveis “Teste” e “Teste TI”. Essa URL envia os campos preenchidos no formulário para o servidor. GET é recomendado para operações como consultas em bancos de dados que não tenham resultados permanentes.

Na submissão de dados via POST, as variáveis submetidas são incluídas no corpo da requisição HTTP, e não via URL. Esse tipo de submissão é considerado mais seguro. O POST é indicado para um processamento no qual o formulário deve inserir um registro em um banco de dados ou no envio de e-mail.

Falta de confidencialidade de HTTP — por padrão, requisições e respostas HTTP são enviadas via TCP para a porta 80, considerada uma porta-padrão. Esse protocolo não fornece nenhum meio de encriptar seus dados, ou seja, os conteúdos são enviados de forma “pura”. Por essa falha na segurança (não conter encriptação), se um atacante conseguir interceptar os pacotes que estão sendo enviados pelo navegador do cliente, poderá ter acesso a qualquer informação que o usuário esteja transmitindo e, inclusive, modificá-la.

Protocolo HTTPS — para resolver problemas de confidencialidade referentes ao Protocolo HTTP, existe o HTTPS (“Protocolo de Transferência de Hipertexto Seguro”) (Figura 5), que tem a mesma sistemática do HTTP, porém incorpora uma camada adicional de segurança, conhecida como SSL (*Secure Socket Layer*) ou TLS (*Transport Layer Security*). Ambos utilizam um certificado para verificar a identidade do servidor e estabelecer um canal de comunicação encriptada entre o navegador e o servidor.



Audiodescrição

A imagem mostra dois blocos verticais retangulares. O bloco à esquerda contém o texto Navegador Web. O bloco à direita contém o texto Servidor Web. Entre eles, há

seis setas horizontais, distribuídas de cima para baixo, representando a troca de mensagens.

A ordem de leitura das setas é:

1. A primeira seta aponta do navegador para o servidor com o texto Funções hash e cifras suportadas.
2. A segunda seta aponta do servidor para o navegador com o texto Funções hash e cifras escolhidas.
3. A terceira seta aponta do servidor para o navegador com o texto Certificado.
4. À esquerda da terceira seta, ao lado do navegador, está o texto Verifica certificado.
5. A quarta seta útil no fluxo (quinta no total) aponta mutuamente do navegador para o servidor com o texto Gera chaves secretas compartilhadas.
6. A última seta aponta mutuamente do servidor para o navegador com o texto Transfere dados em canal seguro.

Figura 5. Como acontece uma requisição entre cliente e servidor via protocolo HTTPS.

Fonte: Goodrich e Tamassia (2013).

Fim da audiodescrição

Certificados de servidores *web* — fornecem uma chave pública do servidor para uso na geração de chaves secretas compartilhadas, como um meio de verificar a identidade de um *site* para seus clientes. Para atingir esse objetivo, certificados são assinados digitalmente usando a chave privativa de um terceiro confiável, conhecido como Autoridade de Certificação (CA, do inglês *Certification Authority*). O proprietário de um *site* obtém um certificado submetendo uma requisição de assinatura de certificado para uma CA e pagando uma taxa. Um certificado de servidor é um atestado do emissor (CA) sobre determinada organização, proprietária do *site*, e contém vários campos, como: nome da Autoridade de Certificação, que emitiu o certificado; número serial, identificador; data de vencimento do certificado; nome de domínio do site; organização que opera; identificador do criptossistema de chave pública usado no servidor; chave pública usada pelo servidor no protocolo HTTPS; identificador da função *hash* de chave pública usada pela CA para assinar o certificado; assinatura digital em todos os outros campos do certificado (Figura 6).

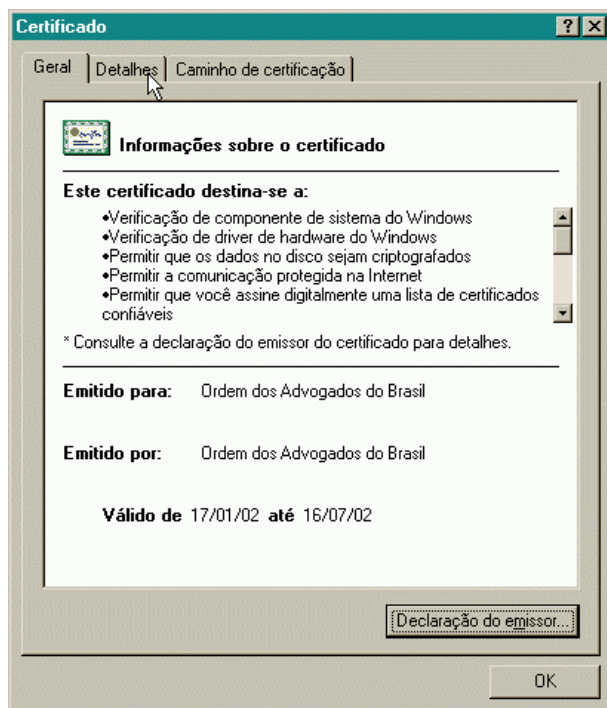


Figura 6. Visualização de um certificado digital.

Fonte: OAB (2018, documento on-line).

Audiodescrição

A imagem mostra uma janela de sistema operacional com bordas em tom bege. Na parte superior, há uma barra de título com o texto *Certificado*. Abaixo da barra, aparecem três abas: *Geral*, *Detalhes* e *Caminho de certificação*. A aba *Geral* está selecionada. Sobre a aba *Detalhes*, há um cursor em formato de seta.

Abaixo das abas, há um quadro com o título *Informações sobre o certificado*. Dentro desse quadro, no canto superior esquerdo, há um ícone pequeno composto por um selo sobre um papel. Abaixo do ícone, aparece o texto completo:

Este certificado destina-se a:

- Verificação de componente de sistema do Windows
- Verificação de driver de hardware do Windows
- Permitir que os dados no disco sejam criptografados
- Permitir a comunicação protegida na Internet
- Permitir que você assine digitalmente uma lista de certificados confiáveis

Consulte a declaração do emissor do certificado para detalhes.

A seguir, aparecem três linhas de identificação:

Emitido para: Ordem dos Advogados do Brasil

Emitido por: Ordem dos Advogados do Brasil

Válido de 17/01/02 até 16/07/02

Na parte inferior direita da janela, há dois botões: à esquerda, um botão cinza com o texto *Declaração do emissor...* e à direita um botão igual com o texto *OK*.

Figura 6. Visualização de um certificado digital.

Fonte: OAB (2018, documento *on-line*).

Fim da audiodescrição

Quando um certificado se torna inválido, a CA o revoga, adicionando seu número serial à lista de revogação de certificado, assinada pela CA e publicada no *site* de revogação. Verificar a validade de um certificado envolve não somente a assinatura no certificado, mas também baixar a lista de revogação de certificado, analisando a assinatura nessa lista e conferindo se o número serial do certificado aparece nessa lista.

A maioria dos navegadores exibe um aviso visual ao estabelecer uma conexão segura, como um ícone de cadeado. Quando um usuário navega em um *site* que tenta estabelecer uma conexão HTTP, mas fornece um certificado expirado, revogado ou inválido, a maioria dos navegadores exibe essa informação e avisa o usuário (Figura 7).

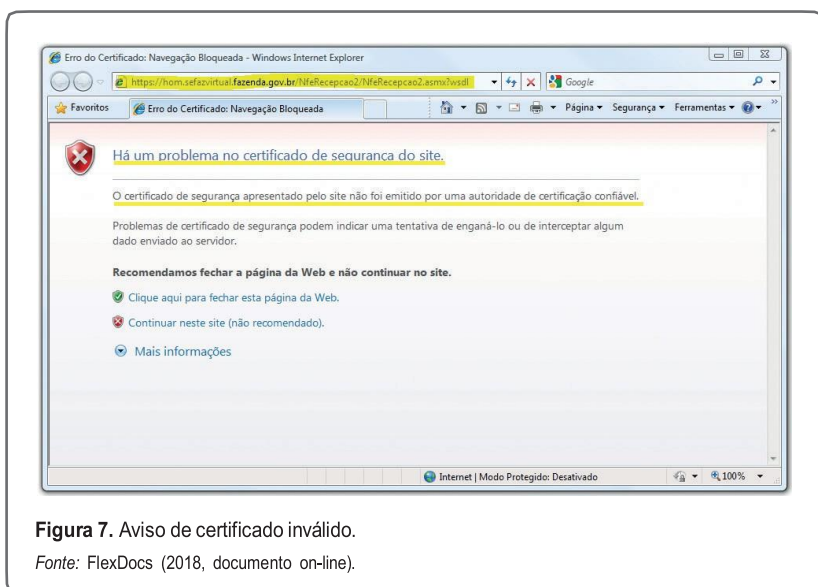


Figura 7. Aviso de certificado inválido.

Fonte: FlexDocs (2018, documento on-line).

Audiodescrição

A imagem mostra a tela de um navegador Internet Explorer. Na parte superior, aparece a barra de título com o texto Erro de Certificado: Navegação Bloqueada – Windows Internet Explorer. Abaixo, a barra de endereços contém a URL iniciada por <https://nonaesfaturafazenda.gov.br/...> e está destacada em amarelo.

No centro da tela, há um grande aviso de segurança. À esquerda desse aviso, há um ícone de um círculo vermelho com um X branco. Ao lado do ícone, aparece o texto: Há um problema no certificado de segurança do site.

Abaixo, em destaque amarelo, há o texto: O certificado de segurança apresentado pelo site não foi emitido por uma autoridade de certificação confiável.

O parágrafo seguinte informa: Problemas de certificado de segurança podem indicar uma tentativa de enganá-lo ou de interceptar algum dado enviado ao servidor.

Em seguida, há recomendações: Recomendamos fechar a página da Web e não continuar no site.

Abaixo aparecem três opções representadas como itens de lista:

- Clique aqui para fechar esta página da Web.
- Continuar neste site (não recomendado).
- Mais informações.

Na barra inferior do navegador há textos indicando Internet e Modo Protegido: Desativado.

Figura 7. Aviso de certificado inválido.

Fonte: FlexDocs (2018, documento *on-line*).

Fim da audiodescrição

Sessões — uma sessão encapsula informações sobre um visitante que persiste além da carga de uma única página, ou seja, um *site* com características de contas e carrinho de compras deve manter o registro de seus visitantes de modo que não se torne necessária a autenticação a cada nova página ou o registro dos números dos itens para posterior inserção em um formulário de pedidos. A informação de sessão deve ser considerada sensível, pois é usada para permitir que os usuários mantenham uma identidade consistente em *sites* que possibilitem acessar contas bancárias, números de cartões de crédito, registro de plano de saúde, CPF, etc. O acompanhamento de uma sessão é considerado um ataque de sequestro de sessão, no qual o invasor poderá ter acesso a todas as informações fornecidas a determinado *site*.

Cookies — são enviados aos clientes pelo servidor *web* e armazenados na máquina do usuário. Quando o usuário visita o *site*, esses *cookies* retornam, inalterados, para o servidor, que pode “relembra-lo” e acessar sua informação de sessão. *Cookies* são transmitidos, normalmente, sem encriptação, usando HTTP, e, como tal, ficam sujeitos a ataques. Para remediar a visualização de dados por meio de *cookies* pode ser configurado um sinalizador de segurança que requer a transmissão de um *cookie* usando HTTPS.

Ataques a clientes

Navegadores *web* são alvos populares de ataques, como os descritos a seguir.

Sequestro de sessão — trata-se de um sinônimo de uma sessão roubada, na qual um invasor intercepta e assume uma sessão legitimamente estabelecida entre um usuário e um *host*, a qual se dá pelo acesso de qualquer recurso autenticado, como um servidor *web*. Nesse tipo de ataque, os invasores se colocam entre o usuário e o *host*, permitindo o monitoramento do tráfego do usuário e o lançamento de ataques específicos. Sendo bem-sucedido no sequestro de sessão, o atacante pode assumir o papel do usuário legítimo ou monitorar o tráfego para injetar ou coletar pacotes específicos a fim de criar o efeito desejado. Com esse ataque, pode-se enviar comandos, roubar identidades e elevar a corrupção de dados. Podemos citar três técnicas de sequestro de sessões:

- **forçar um ID** — o invasor, que geralmente tem algum conhecimento do intervalo de ID disponíveis, adivinha um ID. O atacante pode ser auxiliado pelo uso de referências HTTP, *sniffing*, *cross-site scripting* ou *malware*;

- **roubar um ID** — um invasor roubará um ID usando *sniffing* ou outros meios;
- **calcular um ID** — um invasor tentará calcular um ID de sessão válido simplesmente olhando para um existente e, depois, descobrindo a sequência.

Phishing — roubo de identidade em que o fraudador utiliza um *e-mail* que parece autêntico de uma empresa legítima ou, então, um *site* falsificado para induzir destinatários a fornecerem informações pessoais confidenciais, como o número do cartão de crédito. A maioria dos ataques de *phishing* tem como alvo empresas de serviços financeiros, mais provavelmente pelo alto valor da informação “pescada”. Uma técnica usada pelos atacantes, conhecidos como *phishers*, consiste em, de algum modo, disfarçar o URL do *site* falso para não alertar a vítima sobre algo que possa estar errado.

Sequestro de clique — exploração de um *site* no qual um clique em uma página é usado de uma maneira que não era a pretendida pelo usuário (p. ex., o usuário clica para assistir a um vídeo, mas, em vez de iniciá-lo, redireciona para outra página, indesejada). O sequestro de clique pode ser usado para forçar os usuários a clicarem nos anúncios sem desejarem, aumentando o lucro dos *sites* fraudulentos, ação conhecida como fraude do clique.

Vulnerabilidades em conteúdo — podem estar presentes em um conteúdo dinâmico de mídia. Ocorrem em virtude de ações maliciosas por parte de exibidores de conteúdo de mídia e ferramentas interativas que poderiam estar fornecendo uma experiência segura e agradável ao usuário.

Cross-site Scripting (XSS) — são ataques nos quais a validação inadequada da entrada em um *site* permite que usuários maliciosos injetem um código no site, posteriormente executado no navegador de um visitante. São dois os tipos de ataques XSS:

- XSS persistente — o código que o atacante injeta no site permanece no site por um período, sendo visível para outros usuários;
- XSS não persistente — não permite que o código injetado persista após a sessão do atacante. Um exemplo refere-se à página de busca de determinado *site*, que retorna uma consulta; ao ser digitada uma pesquisa, como “informática”, a página resultante iniciará com uma linha que diga “Resultados da busca sobre informática”. Caso a entrada do usuário não seja filtrada para certos caracteres, a injeção de segmentos de código na caixa de pesquisa poderia resultar na inclusão de código na página de resultados de pesquisa, como conteúdo da página, executando como código no navegador do cliente.

Cross-site request forgery (CSRF) — também conhecido como requisição

forjada de sites, é essencialmente oposto ao XSS. Explora a confiança de um *site* em relação a um usuário específico. Nesse ataque, um *site* malicioso faz o usuário executar, sem saber, comandos em um terceiro *site*, no qual o usuário confia.

Ataques a servidores

São diários os ataques à tecnologia *web*. A partir de agora, exploraremos um pouco sobre *scripts* e alguns ataques a servidores.

Scripts de servidores — o código dos servidores é executado no servidor, motivo pelo qual somente é visível ao cliente o resultado da exibição desse código, e não seu código-fonte. Em geral, o código do servidor executa operações e, eventualmente, gera um código HTML-padrão, que será enviado como resposta a uma requisição do cliente.

O PHP é uma linguagem de hipertexto de pré-processamento, que possibilita que servidores *web* usem *scripts* para criar, de maneira imediata e dinâmica, arquivos HTML para usuários com base em diversos fatores, como hora do dia, entradas fornecidas pelo usuário ou consultas em bancos de dados. O código PHP é embutido em um arquivo PHP ou HTML e armazenado em um servidor *web*, que o executa por meio de um módulo de pré-processamento PHP no *software* do servidor WEB para criar um arquivo de saída HTML enviado a um usuário.

Vulnerabilidades de inclusão de script no servidor — um *script* é incluído no servidor de forma vulnerável, o que é explorado por um atacante para injetar um código de *script* arbitrário no servidor, que o executa para realizar uma ação desejada pelo invasor. Compreendem alguns tipos de inclusão de arquivos:

- inclusão de arquivo remoto (RFI) — tem se tornado menos comum, pois a maioria das instalações PHP não permite, por padrão, que o servidor execute um código hospedado em um servidor separado. Esse tipo de ataque acontece a partir da verificação da necessidade de que o código do servidor execute um código externo, contido em outros arquivos, além daquele que está sendo executado naquele momento;



Exemplo

Um exemplo prático de inclusão de arquivo remoto consiste na inclusão de um cabeçalho e um rodapé comum a todas as páginas de um *site*.

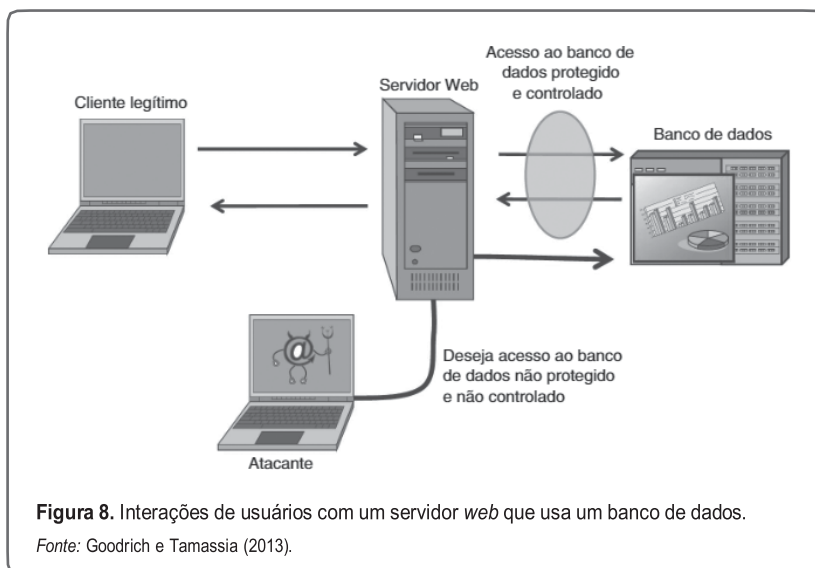
- inclusão de arquivo local (LFI) — faz o servidor executar um código injetado que, de outro modo, não seria executado (normalmente para um propósito malicioso). A diferença entre a LFI e a RFI reside no fato de que o código executado não está contido em um servidor remoto, mas no próprio servidor da vítima;



Exemplo

Um atacante poderia navegar na URL `http://vitima.com/index.php?page=admin/secretpage`, que, se acessada, pode fazer com que a página de índice execute a `secretpage.php`, anteriormente protegida. Algumas vezes, ataques LFI permitem que um atacante acesse arquivos no sistema do servidor web fora do diretório raiz da *web*.

- bancos de dados e ataques de injeção SQL — muitos *sites* utilizam bancos de dados, um sistema que armazena informação de maneira organizada e produz relatórios sobre essa informação, com base em consultas apresentadas por usuários. Normalmente, invasores se interessam em acessar informações armazenadas em um banco de dados (Figura 8). Portanto, a maioria das interações com banco de dados baseadas em *web* é realizada fora do servidor, de maneira invisível para o usuário, de modo que as interações entre os usuários e o banco de dados possam ser cuidadosamente controladas. O objetivo de um atacante, obviamente, consiste em romper essa interação controlada com o banco de dados para obter acesso direto a ele.



Audiodescrição

A imagem apresenta, à esquerda, um computador portátil aberto, com tela em cinza, identificado pelo texto *Cliente legítimo*. Uma seta preta horizontal aponta desse computador para o centro da figura.

No centro da imagem, há um servidor *web* representado como um gabinete vertical em tom cinza. Acima dele, está o texto *Servidor Web*.

À direita do servidor, há uma forma oval cinza clara com duas setas horizontais apontando para ela e retornando ao servidor. Acima dessa área, está o texto *Acesso ao banco de dados protegido e controlado*. À direita da forma oval, há a imagem de um banco de dados, representado por um monitor que exibe gráficos e um gabinete com discos. Abaixo dessa representação, está o texto *Banco de dados*.

Na parte inferior esquerda da figura, há outro computador portátil. Na tela, aparece um desenho estilizado de um inseto, simbolizando *malware*. Abaixo dele, está o texto *Atacante*. Uma seta curva preta parte desse computador em direção ao servidor. Sobre a seta, está o texto *Deseja acesso ao banco de dados não protegido e não controlado*.

Figura 8. Interações de usuários com um servidor *web* que usa um banco de dados.

Fonte: Goodrich e Tamassia (2013).

Fim da audiodescrição

Vulnerabilidades em protocolos para internet

Outra forma de classificação dos ataques é em relação aos protocolos TCP/IP. Segundo Forouzan e Fegan (2009), os protocolos para a internet, também conhecidos por protocolos TCP/IP, são distribuídos em cinco camadas: aplicativo, transporte, rede, enlace de dados e física. Na camada de aplicativos, temos protocolos como HTTP (*Hypertext Transfer Protocol*), FTP (*File Transfer Protocol*), DNS (*Domain Name System*), SMTP (*Simple Mail Transfer Protocol*), entre outros.

Já na camada de transporte, temos os protocolos TCP (*Transmission Control Protocol*, Protocolo de Controle da Transmissão), UDP (*User Datagram Protocol* - Protocolo de Datagrama do Usuário), SCTP (*Stream Control Transmission Protocol*).

Na camada de rede temos o protocolo IP (*Internetworking Protocol*), que suporta ICMP (*Internet Control Message Protocol*), IGMP (*Internet Group Management Protocol*), ARP (*Address Resolution Protocol*) e RARP (*Reverse Address Resolution Protocol*).

Por fim, nas camadas física e de enlace de dados, temos os protocolos que são definidos pelas redes subjacentes, como MAC (*Media Access Control Address*), NDP (*Neighbor Discovery Protocol*), entre outros.

Estes protocolos são vulneráveis às falhas como SYN *flooding* (ataca o TCP), IP *spoofing* (IP, e-mail e DNS), sequestro de sessão (HTTP), *source routing* e ataques ICMP (IP, ICMP), discutidos anteriormente. Mas, adicionalmente, segundo Alotaibi et. al. (2017) existem problemas de segurança que são mais recorrentes nas camadas de aplicativo, transporte e rede do TCP/IP, conforme descrito a seguir:

- Camada de aplicativo: no HTTP podem ocorrer ataques de *caching*, sequestro de sessão, ataques de repetição, e envenenamento de *cookies*. No protocolo DNS, os ataques mais frequentes são sequestro de ID DNS, DNS *spoofing* e envenenamento de cache DNS.
- Camada de transporte: técnicas para escaneamento de portas TCP/UDP, ataque TCP LAND (*Local Area Network Denial*), ataque de meia varredura de IP, ataque de geração de número de sequência TCP e SYN *flooding*.
- Camada de rede: tentativas de força bruta de senha, *spoofing*, HTTP *flooding*, *click jacking*, negação de serviço, detecção de pacotes, coleta ilegal de dados, sequestro e interceptação de conexões, restabelecimento da conexão, roteamento *multicast*, ataques *Smurf* e

Fraggle (ataques distribuídos de negação de serviço).

Há também outros ataques, como o Source Routing, que é uma variação de IP *spoofing*, onde o *host* de origem pode especificar a rota que o receptor deve usar para responder. Adicionalmente, há os ataques de crackers, quando um *host* é violado para ser usado como meio para outros alvos, por meio da instalação de trojans ou outras ferramentas, e os ataques de *script kiddies*: por exemplo, quando um site é “pixado”, ou os dados da página inicial são modificados por pessoas inexperientes, que usam códigos desenvolvidos por hackers profissionais.

Para a proteção ou defesa contra esses ataques cujo alvo são os protocolos para internet, é importante o uso de criptografia nos protocolos e o isolamento físico. Outras três técnicas que podem ser utilizadas para a proteção contra as vulnerabilidades são a filtragem de pacotes, uso de autenticação e *firewalls*. Segundo Forouzan e Fegan (2009), no nível IP, pode ser utilizado o IPSec (*IPSecurity*) é composto por uma coleção de protocolos que oferece segurança a um pacote IP. Já na camada de aplicativo, uma alternativa para a segurança no envio de e-mails é o PGP (*Pretty Good Privacy*), que se utiliza de assinatura digital e criptografia. Concluindo, é importante ter conhecimento tanto das técnicas de ataque quanto dos possíveis mecanismos de defesa, para que possamos melhor gerenciar a segurança em equipamentos que façam parte de redes de computadores.



Referências

CANALTECH. *O que é DoS e DDoS?* 2018. Disponível em: <<https://canaltech.com.br/produtos/O-que-e-DoS-e-DDoS/>>. Acesso em: 17 dez. 2018.

FLEXDOCS. *Certificados digitais*. 2018. Disponível em: <<http://www.flexdocs.com.br/guianfe/certificado.servidor.html>>. Acesso em: 17 dez. 2018.

GOODRICH, M, T.; TAMASSIA, R. *Introdução à segurança de computadores*. Porto Alegre: Bookman, 2013.

OAB. *Visualizando os certificados instalados*. 2018. Disponível em: <http://cert.oab.org.br/m_ie_1c.html>. Acesso em: 17 dez. 2018.

PADILHA, R. 99 *Conceitos Ilustrados de Hospedagem*: tentando compreender um vendedor de Startup. 18 jul. 2015. Disponível em: <<http://midiasocialparanegocios.blogspot.com/2015/>>. Acesso em: 17 dez. 2018.

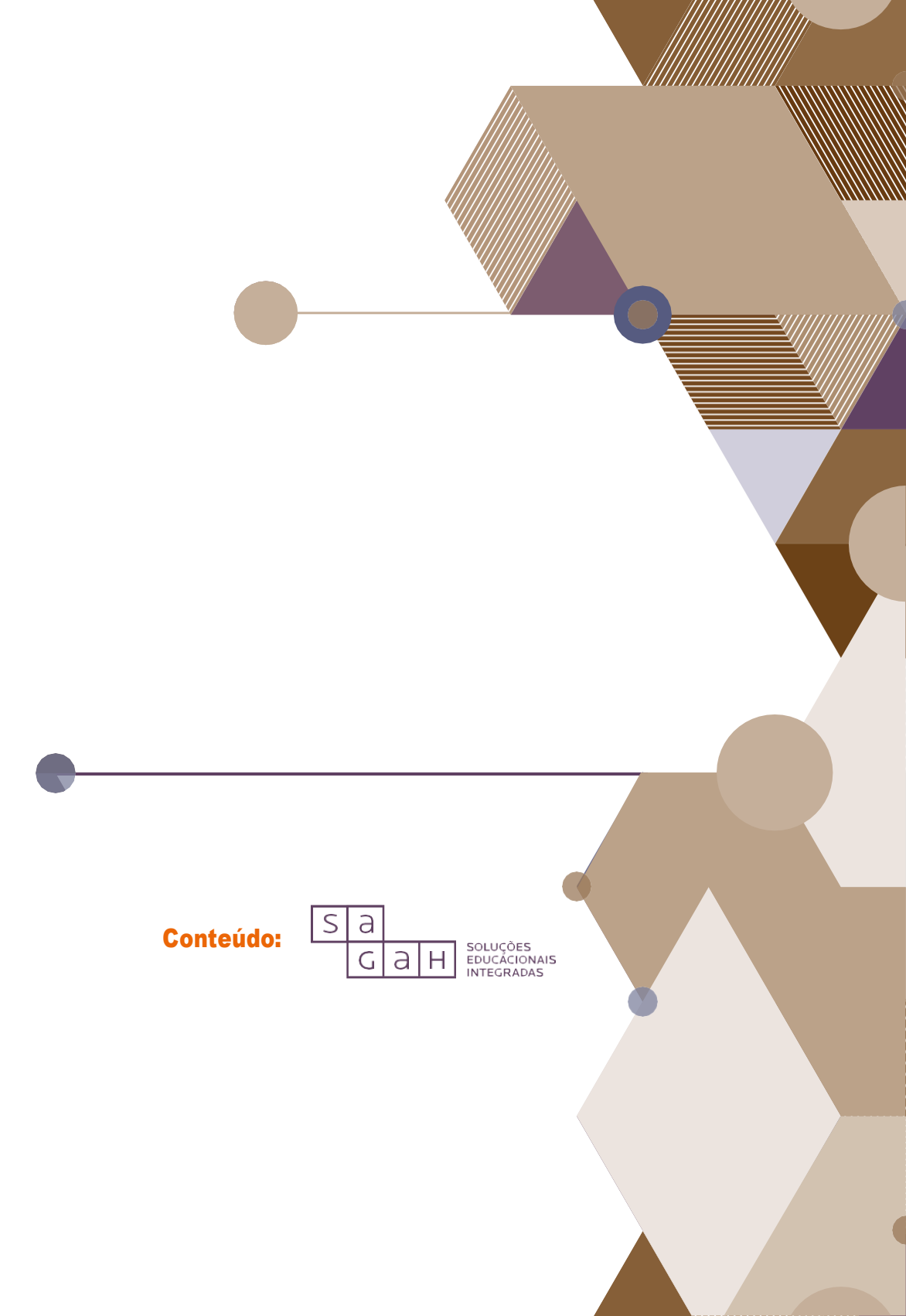
TCP. *Uma conexão normal cliente-servidor*: o aperto de mão em três etapas é realizado corretamente. 22 jan. 2012. Disponível em: <https://pt.wikipedia.org/wiki/SYN_Flood#/media/File:Tcp_normal.svg>. Acesso em: 17 dez. 2018.

Leituras recomendadas

HD STORE. *Quais os tipos de ataques cibernéticos existentes?* 2018. Disponível em: <<https://blog.hdstore.com.br/tipos-ataques-ciberneticos/>>. Acesso em: 17 dez. 2018.

MCCLURE, S.; SCAMBRAY, J.; KURTZ, G. *Hackers expostos*: segredo e soluções para a segurança de redes. 7. ed. Porto Alegre: Bookman, 2015.

NAKAMURA, T. E.; GEUS, P. L. *Segurança de Redes em ambientes corporativos*. São Paulo: Novatec, 2007.



Conteúdo:



SOLUÇÕES
EDUCACIONAIS
INTEGRADAS